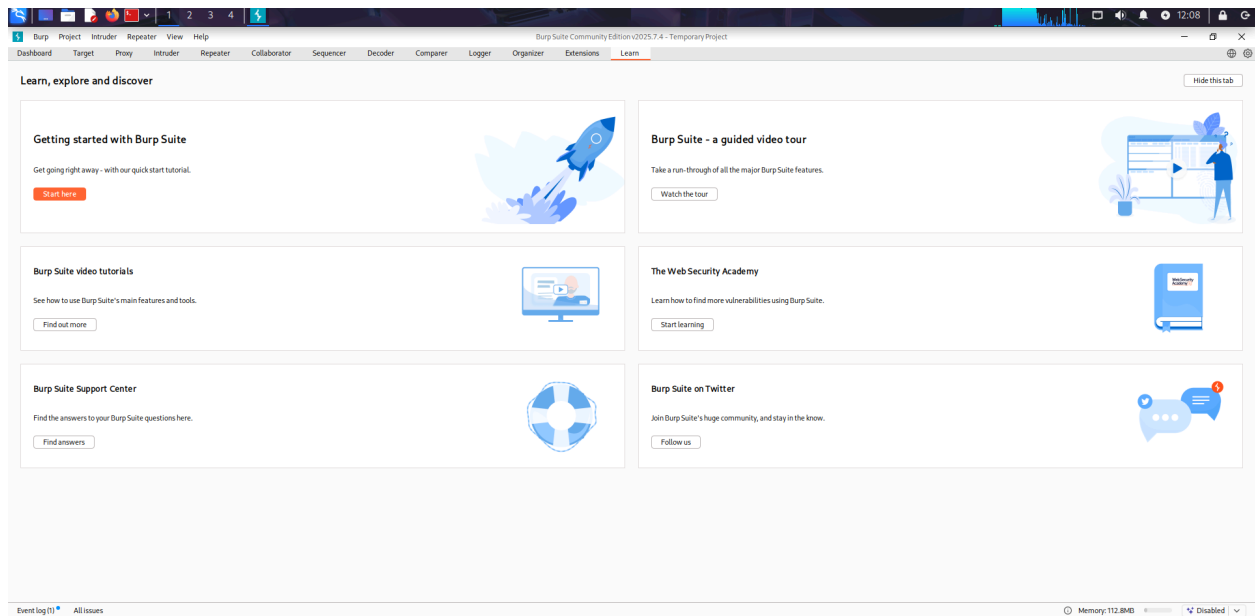


Task 1: Install and Launch Burp Suite Community Edition

Installation Steps

1. Download Burp Suite Community Edition from the official PortSwigger website.
2. Run the installer.
3. Launch Burp Suite.
4. Select Temporary project if prompted.
5. Select the default configuration.
6. Click Start Burp.



Task 2: Intercept HTTP Requests Using Burp Suite Proxy

Target:

<http://testphp.vulnweb.com/>

Procedure

1. Open Burp Suite.
2. Go to Proxy → Intercept.
3. Make sure Intercept is ON.
4. Configure the browser to use Burp's proxy if it is not already configured.
5. Open the demo website.
6. Navigate to its login-related functionality.

7. Submit a test request using only the demo account/test data provided by the site.
8. Burp Suite will intercept the HTTP request.
9. Examine the request in the Proxy tab.

Example Request Headers

An intercepted HTTP request may contain headers similar to:

- GET / HTTP/1.1
- Host: testphp.vulnweb.com
- User-Agent: Mozilla/5.0
- Accept: text/html,application/xhtml+xml
- Accept-Language: en-US,en;q=0.9
- Connection: close

Task 3: Three Open-Source VAPT Tools Listed by OWASP

OWASP maintains resources containing security testing tools and projects. Its Web Security Testing Guide includes freely available tools such as ZAP, while OWASP's project inventory includes projects such as Amass and Dependency-Check.

1. OWASP ZAP

Purpose: OWASP ZAP (Zed Attack Proxy) is an open-source web application security testing tool that can automatically scan web applications and also provide tools for manual penetration testing.

2. OWASP Amass

Purpose: OWASP Amass is an open-source attack-surface mapping and reconnaissance tool used for network mapping, DNS enumeration, and external asset discovery.

3. OWASP Dependency-Check

Purpose: OWASP Dependency-Check performs software composition analysis by identifying third-party dependencies and checking whether they contain publicly known vulnerabilities.

Task 4: Basic Vulnerability Scan Using OWASP ZAP

Target

- <http://testphp.vulnweb.com/>

Procedure Using OWASP ZAP

1. Install and open OWASP ZAP.
2. Select Quick Start.
3. Choose Automated Scan.
4. Enter:
 - <http://testphp.vulnweb.com/>
5. Start the scan.
6. Wait for the scan to finish.
7. Open the Alerts section.
8. Record two alerts reported by your actual scan.

Task 5: SQL Injection Test Using Burp Suite

AI-Generated Step-by-Step Guide

The following procedure is designed for the intentionally vulnerable training site specified in the assignment.

Step 1: Start Burp Suite

Open Burp Suite Community Edition and create a temporary project.

Step 2: Configure the Browser

Configure the browser to send HTTP traffic through Burp Suite's local proxy.

The standard Burp proxy listener is commonly:

- 127.0.0.1:8080

Step 3: Turn Intercept On

Go to:

- Proxy → Intercept → Intercept is ON

Step 4: Open the Demo Application

Browse to:

<http://testphp.vulnweb.com/>

Step 5: Find an Input Point

Use a search, login, or other input functionality provided by the intentionally vulnerable application.

Submit a normal test value first.

Step 6: Inspect the Request

Burp will intercept the HTTP request.

Look for parameters such as:

id=

search=

username=

or other input parameters.

Step 7: Send the Request to Repeater

- Right-click the intercepted request and select:
- Send to Repeater
- Open the Repeater tab.

Step 8: Test the Parameter

Change only the selected input parameter and send the request.

For a controlled training exercise, use harmless SQL-injection test input appropriate to the demo application and observe whether the application's response changes unexpectedly.

Step 9: Compare Responses

Compare the normal request with the modified request.

Look for differences such as:

- Different HTTP status codes
- Database error messages
- Unexpected page content
- Changes in the number or type of returned records
- Other unusual application behavior
- Step 10: Document the Result

Record:

- URL tested
- Parameter tested
- Normal response
- Modified response
- Evidence observed
- Potential security impact